

Esercitazione svolta: definire il perimetro e la superficie di attacco di un semplice sistema digitale

testi di riferimento aggiuntivi:

-NIST Special Publication 800-207 – Zero Trust Architecture.

-SP 800-53 (controlli di sicurezza) e SP 800-30 (risk assesment).

Descrizione generale del sistema

Il sistema e-commerce “trova compra” è una piattaforma online di vendita di prodotti, sviluppata in architettura cloud ibrida.

Comprende un front-end web accessibile da browser e app mobile, un application server che espone API REST, un database relazionale gestito in cloud (PostgreSQL su AWS RDS), un gateway di pagamento esterno conforme a PCI-DSS, un servizio di autenticazione federata basato su OpenID Connect/OAuth2 e un modulo di amministrazione accessibile tramite VPN con autenticazione a due fattori.

—

Componenti logiche principali

Zona pubblica (front-end): espone le interfacce di catalogo, ricerca e login, accessibili da Internet tramite HTTPS.

Zona applicativa (application layer): contiene la logica di business, la gestione ordini e l'autenticazione utenti; comunica solo via API con la zona dati.

Zona dati (database e storage): contiene dati personali e transazionali, non accessibile direttamente da Internet.

Servizi esterni integrati: gateway di pagamento, notifiche, sistemi di analytics, accessibili tramite token temporanei e autenticazione mutuale TLS.

Classificazione del perimetro secondo il NIST SP 800-207

Nel modello Zero Trust, il perimetro non è una barriera di rete, ma una funzione logica di controllo dell'identità e del contesto di accesso. L'architettura è segmentata in micro-perimetri, ciascuno con policy dedicate.

Perimetri logici identificati:

- Perimetro utente: autenticazione tramite Identity Provider (IdP) con token OAuth2 e MFA.
- Perimetro API: verifica del contesto di accesso (origine, token, tempo di sessione, ruolo).
- Perimetro amministrativo: accesso consentito solo da VPN con MFA e controllo continuo dell'identità.
- Perimetro dati: accesso consentito solo ai servizi applicativi autorizzati secondo il principio del "least privilege".

Ogni accesso è verificato dinamicamente da un PolicEnforcement Point (PEP), secondo le regole definite nel Policy Decision Point (PDP), come previsto dal framework NIST SP 800-207.

Analisi della superficie di attacco

La superficie di attacco rappresenta l'insieme dei punti attraverso i quali un attaccante può interagire con il sistema.

Superficie di rete: include le porte HTTPS del front-end e delle API e gli endpoint VPN per accesso amministrativo. I rischi principali sono attacchi DDoS, scansioni e sfruttamento di vulnerabilità TLS.

Superficie applicativa: comprende i form di login, i moduli di registrazione e gli endpoint API REST. I rischi includono SQL injection,

XSS e session hijacking.

Superficie logica: riguarda i token OAuth2, la gestione delle sessioni e dei ruoli. I rischi sono replay di token, escalation di privilegi e configurazioni errate.

Superficie dati: concerne il database accessibile solo tramite API. Il rischio principale è l'esposizione di dati sensibili tramite query o log non cifrati.

Superficie umana: include credenziali deboli, phishing e errori operativi. Il rischio è la compromissione dell'account amministratore o sviluppatore.

—

Misure di hardening per ridurre la superficie di attacco

Front-end: utilizzo di Web Application Firewall (WAF) e Content Security Policy; aggiornamento automatico delle librerie JavaScript.

Application layer: validazione input, logging strutturato e separato, rate limiting sugli endpoint API.

Database: accesso solo tramite rete privata, cifratura a riposo (AES-256) e in transito (TLS 1.3).

Gestione identità: autenticazione multifattore e token con scadenza breve.

Amministrazione: VPN segmentata, audit continuo e registro accessi firmato digitalmente.

—

Rischi residui e controlli NIST correlati

Accesso non autorizzato: mitigato da controlli NIST AC-2, AC-3, AC-17 e IA-2, con implementazione di MFA, policy di sessione e audit accessi.

Manipolazione dei dati: mitigata da controlli NIST SC-8 e SC-13,

mediante cifratura TLS e AES e funzioni di hashing.

Attacchi web applicativi: mitigati da controlli NIST SI-10 e RA-5, con validazione input, WAF e test periodici di vulnerabilità.

Violazione dell'identità amministrativa: mitigata da controlli IA-5 e AC-6, con segregazione dei ruoli e logging continuo.

Interruzione del servizio: mitigata da controlli CP-10 e SI-4, con backup, monitoraggio e alert automatici.

Sintesi finale

Il perimetro dell'e-commerce è distribuito: ogni livello (utente, API, dati, amministrazione) costituisce un micro-perimetro regolato da policy dinamiche di accesso.

La superficie di attacco è gestita mediante misure multilivello di hardening, autenticazione forte e monitoraggio continuo.

L'architettura è coerente con i principi del NIST SP 800-207 (Zero Trust) e del NIST SP 800-53, in particolare per autenticazione continua, cifratura, logging e applicazione del principio del "least privilege".

Il sistema si fonda sul monitoraggio continuo (ISCM) e sulla riduzione progressiva della superficie di esposizione, in linea con il framework di gestione del rischio NIST SP 800-37 Rev.2.

